AFFAN AHMED

Offensive Security Engineer | Application Security Researcher | CVE Researcher

Kolkata, India | +91 8583865960 | affanahmed3104@gmail.com

LinkedIn: linkedin.com/in/affan-ahmed-70a406178 | GitHub: github.com/ctflearner | Exploit-DB: Author #11358

PROFESSIONAL SUMMARY

Offensive Security Engineer with close to 3 years of experience in Gray/Black-box Web, API, and Android penetration testing. 16+ assigned CVEs (NIST NVD validated). Exploit-DB published author (ID #11358). NCIIPC (Govt. of India) acknowledged researcher. Audited Fortune 500 SaaS and Fintech platforms. Delivered 40+ government and institutional assessments under CERT-In standards. Active contributor to SecLists, Nuclei Templates, PortSwigger Bambdas, OWASP, and HackTricks.

CORE COMPETENCIES

Offensive Security	Web App Pentesting (OWASP Top 10), API Security, Android Pentesting, Gray/Black-box Testing, CVE Research, Responsible Disclosure
Vuln Classes	SSRF, SQLi, XSS, IDOR/BOLA, BAC, CSRF, Path Traversal, Auth Bypass, RCE, Race Conditions, Business Logic Flaws
Mobile Security	Component Export (IPC), SSL Pinning Bypass, Insecure Storage, Deep Link Injection, Static & Dynamic Analysis
Tools	Burp Suite Pro, Nuclei, SQLMap, Nmap, ffuf, Postman, MobSF, JADX, Frida, OWASP ZAP, Exploit-DB, Google Dorking
Compliance	CERT-In, CVSS, OWASP Testing Guide, PTES, VAPT Reporting, Remediation Validation

PROFESSIONAL EXPERIENCE

Associate Security Engineer

Sep 2025 - Present

we45 PVT LTD

- Fortune 500 & SaaS Platform Audits: Assessed core sub-modules and proprietary AI model integrations for enterprise SaaS platforms (e.g., Sprinklr); discovered 20+ Broken Access Control (BAC) vulnerabilities, Server-Side Request Forgery (SSRF), and critical injection flaws.
- Fintech & Banking Infrastructure: Led external network perimeter and API assessments for major financial institutions including Prudential and ADCB Bank, identifying cross-tenant data visibility issues, input handling flaws, and privilege escalation vectors.
- API & Mobile Penetration Testing: Conducted comprehensive evaluations of internal REST APIs and Android clients (Movius, Seven-Up), isolating a critical rate-limiting absence in high-traffic endpoints that rendered client servers vulnerable to complete business interruption and severe financial overhead.
- Web App Security & Code Review: Performed gray-box assessments for multiple product release versions (Bluescape, Fintellix), reporting critical cross-site scripting (XSS), complex race conditions, and business logic flaws. Complemented dynamic testing with static analysis to catch trust boundary violations before production.
- Remediation & Technical Advisory: Authored standard pre-engagement documentation and engineered CERT-In compliant reporting templates. Managed remediation validation cycles with enterprise engineering teams to eliminate false positives and maintain a zero regression rate on validated fixes.

Security Analyst

Nov 2023 - Apr 2025

Prime Infoserv PVT LTD

- 40+ High-Profile Client Audits: Performed full-cycle WAPT (audit, remediation, revalidation) across government, healthcare, financial, education, judiciary, and energy sectors, including ISRO, IIM Ahmedabad, AIIMS Raipur, Apollo Hospitals, Karnataka High Court, and IREDA.
- Banking RCE Discovery: Led technical audits across 15+ in-house applications; detected and successfully demonstrated a critical Remote Code Execution (RCE) in a banking sector core application.
- Operational Optimization: Redesigned technical reporting templates to streamline vulnerability reproduction and remediation advice, reducing overall auditing turnaround time while maintaining rigorous audit quality.
- End-to-End Project Delivery: Led end-to-end project delivery, successfully taking over pending enterprise engagements and ensuring on-schedule delivery of all CERT-In compliance documentation.

Security Intern

Sep 2022 - Dec 2022

CyberSRC Consultancy

- Performed SAST on Android APKs to detect code-level vulnerabilities and insecure coding patterns.

CVE RESEARCH & VULNERABILITY DISCLOSURES

Credited with 16+ officially assigned CVEs across web (10) and Android (6) platforms, validated by NIST National Vulnerability Database (NVD). Vulnerability classes include Authentication Bypass, SSRF, SQL Injection, Path Traversal, Broken Access Control, IDOR, XSS, CSRF, Improper Validation, Android Component Export, Deep Link Code Injection, Insecure Storage, SSL Pinning Bypass, and Insufficient Permissions Handling. Severity range: 1 Critical, 9 High, 6 Medium.

CWE Vulnerability Research Focus:
CWE-918 (SSRF), CWE-22 (Path Traversal), CWE-1284 (Improper Validation), CWE-798 (Hardcoded Credentials). In-Progress Research: CWE-117 (Log Injection), CWE-112 (Missing XML Validation).

ACHIEVEMENTS & RECOGNITION

- Exploit-DB Published Author (ID #11358) - Multiple exploits and GHDB entries accepted by OffSec.
- NCIIPC (Govt. of India) Newsletter Featured Researcher, October 2023 - Responsible disclosure to critical infrastructure.
- Inflectra Hall of Fame - High-impact responsible vulnerability reporting in enterprise software.
- Nuclei Templates Contributor - YAML detection templates for ProjectDiscovery's scanner, used globally.

OPEN SOURCE CONTRIBUTIONS

SecLists (featured in 2024.4 release) | PortSwigger Bambdas (Burp Suite Pro snippets) | OWASP Community (security tools docs) | HackTricks Wiki (exploitation docs) | Payatu Security (tool setup docs) | ProjectDiscovery Nuclei Templates (CVE detection YAML)

CERTIFICATIONS

- **Certified AppSec Practitioner (CAP)** - The SecOps Group
- **Certified API Security Analyst (CASA)** - APIsec University
- **Certified Mobile Pentester - Android (CMPEN)** - The SecOps Group
- **Certified Red Team Analyst (CRTA)** - CyberWarFare Labs
- **Practical Junior Penetration Tester (PJPT)** - TCM Security
- **eWPTX - Web App Pentester eXtreme (Pursuing)** - INE Security

EDUCATION

B.Tech in Information Technology (CGPA: 8.94/10) Aug 2019 - Jul 2023

Calcutta Institute of Engineering and Management (CIEM)

LANGUAGES

English | Hindi | Bengali